PENSE-BÊTE · TECHNIQUE ET COMMANDES

Authentification et contrôle d'accès Debian

07-55 Référence Debian - Authentification et contrôle d'accès — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. PAM assure une authentification souple pour les logiciels tandis que NSS fournit le service de noms pour la bibliothèque C.
2. Le mot de passe chiffré est stocké de manière sécurisée dans le fichier /etc/shadow et non plus dans /etc/passwd.
3. Les cgroups permettent d'isoler les processus et de contrôler les ressources via une hiérarchie unifiée.

Synthèse des fichiers et commandes

Notion	À retenir
Fichiers de configuration	/etc/passwd (`-rw-r--r--`), /etc/shadow (`-rw-r-----`, root/shadow) et /etc/group (`-rw-r--r--`, root/root). /etc/gshadow existe mais peu utilisé.
Structure des entrées	`/etc/passwd` : nom, mot de passe (`x`), UID, GID, commentaire, répertoire, shell. `/etc/shadow` : mot de passe chiffré, dates (jours depuis **01/01/1970**), délais. `/etc/group` : nom, mot de passe, GID, membres.
Commandes de gestion	`getent` (passwd, shadow, group) pour consulter ; `passwd` pour gérer le mot de passe (`-e` : mot de passe expiré, à changer à la connexion) ; `chage` pour la validité ; `mkpasswd` ou `openssl passwd` pour chiffrer.

Synthèse PAM et NSS

Notion	À retenir
Rôles	PAM : authentification souple pour logiciels ; NSS : service de noms pour bibliothèque C (ex: `ls`, `id`). Sous `systemd`, `libpam-systemd` gère les sessions via `logind`.
Paquets et fichiers	PAM : `/etc/pam.d/` ; NSS : `/etc/nsswitch.conf`. Paquets : `libpam-modules`, `libc6`, `libpam-doc`. Modules : `pam_access(8)`, `pam_group(8)`. Variables : `/etc/environment` ou `pam_env(8)`.
Gestion centralisée	LDAP : `OpenLDAP`, paquets `libpam-ldapd` et `libnss-ldapd` (utiliser SSL/TLS). Cache : `nscd(8)`. Windows : `winbind` et `libpam_winbind`. Alternative : `nis` (NIS/NIS+).

Sécurité des mots de passe et des communications

Notion	À retenir
Qualité et génération	Au moins **6 à 8** caractères avec **minuscules**, **chiffres (0-9)** ou **ponctuation**. Outils : `mkpasswd` (**whois**) ou `openssl passwd` (**openssl**). `libpam-cracklib` impose des règles sévères.
Services réseau TLS/SSL	Chiffrer la communication via **TLS** ou **SSL**. Ports : **443** (**https**), **993** (**imaps**), **587** (remplace **SMTP 25**). Sécurisation mot de passe seul : **APOP** (**POP**) ou **CRAM-MD5** (**SMTP**, **IMAP**).
Protocole SSH	Client **OpenSSH** et démon **sshd**. Méthodes : **clé publique** (sans mot de passe) ou **tunnels sécurisés** (**POP**, **X**). Protection : `fail2ban` (bannit les **IP** avec erreurs) ou `knockd` (tocage à la porte).

Protection de l'accès administrateur et du système

Notion	À retenir
Sécurité physique et démarrage	Empêcher l'accès au **HDD/SSD** ; verrouiller **UEFI/BIOS** (boot amovible) ; mot de passe **GRUB** (session interactive et édition menu) ; chiffrement **dm-crypt** et **initramfs**.
Accès compte root	Restreindre `su` via `pam_wheel.so` dans `/etc/pam.d/su` ; `sudo` et **PolicyKit** (détail ci-dessous).
Défense force brute	Pare-feu essentiel ; `fail2ban`, `knockd` (voir SSH) ; `libpam-shield` (verrouillage des attaquants distants).

Synthèse des contrôles d'accès

Notion	À retenir
ACL et sudo	ACL : droits spécifiques (signe `+` dans `ls -la`, voir avec `getfacl`). `sudo` : privilèges limités via `/etc/sudoers`, journalise les actions.
PolicyKit	Contrôle des droits globaux. Les applications graphiques l'utilisent pour échanger avec des processus privilégiés. Limité aux membres du groupe **sudo** sur Debian.
Restriction services	Désactiver les serveurs inutilisés. Méthodes : **PAM**, `/etc/default/nom_programme`, unité **systemd**, `/etc/hosts.allow`/`.deny`, `/etc/at.allow`, `/etc/cron.allow` ou **netfilter**.

Sécurité avancée du noyau Linux

Notion	À retenir
LSM et capacités	LSM permet l'imbrication de contrôles (**AppArmor**, **SELinux**, **Smack**, **Tomoyo**). Les **capacités** divisent les privilèges du superutilisateur en unités distinctes (disponibles depuis noyau **2.2**).
Espaces de noms	Enveloppent une ressource globale en abstraction pour isoler les processus. Depuis noyau **5.6**, il existe **huit** types d'espaces de noms.
Cgroups et conteneurs	Depuis **Debian 11 Bullseye (2021)**, hiérarchie unifiée **cgroups-v2**. Utilisés par **Systemd**, pour les bacs à sable et les conteneurs (**Docker**, **LXC**).

Pièges et confusions

- ⚠ Confondre le rôle de PAM (authentification logicielle) avec celui de NSS (service de noms pour ls ou id).
- ⚠ Croire que la commande su gère nativement le groupe wheel sans l'activation de pam_wheel.so dans /etc/pam.d/su.
- ⚠ Penser que le mot de passe chiffré se trouve encore dans le fichier /etc/passwd.
- ⚠ Oublier qu'une erreur de configuration de PAM peut bloquer l'accès au système et nécessite un CD de secours.
- ⚠ Utiliser des protocoles en texte clair comme le port 80 ou le port 21 qui présentent des risques d'interception.

Sigles et définitions

PAM Modules attachables d'authentification offrant un mécanisme d'authentification souple pour les logiciels applicatifs.

NSS Name Service Switch fournissant un mécanisme souple de service de noms utilisé par la bibliothèque standard C.

LDAP Lightweight Directory Access Protocol permettant la mise en œuvre d'une gestion centralisée du système sur un réseau.

ACL Listes de contrôle d'accès constituant un sur-ensemble des permissions normales du système de fichiers.

LSM Linux Security Module fournissant un mécanisme permettant d'imbriquer divers contrôles de sécurité dans des extensions du noyau.

sudo Programme conçu pour permettre à un administrateur système de donner des privilèges d'administration limités aux utilisateurs.

cgroups Hiérarchie utilisée pour isoler les processus et permettre le contrôle des ressources.

Auto-test

1. Quel fichier contient le mot de passe chiffré ?
2. Quel outil permet de consulter les entrées passwd, shadow ou group ?
3. Quel composant limite l'administration au groupe sudo sur Debian ?
4. Quel outil bannit les IP après des erreurs d'authentification ?
5. Depuis quelle version de Debian utilise-t-on la hiérarchie unifiée cgroups-v2 ?

Réponses : **1.** /etc/shadow · **2.** getent · **3.** PolicyKit · **4.** fail2ban · **5.** Debian 11 Bullseye (2021)

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.